UNIVERSIDADE NOVE DE JULHO

PROJETO EM GESTÃO DE SISTEMAS COMPUTACIONAIS
DISCIPLINA 3 — SEGURANÇA DA INFORMAÇÃO

Sistema de Controle de Estoque — Tauste Roupas

SÃO PAULO
2026

DISCIPLINA 3 — SEGURANÇA DA INFORMAÇÃO:

Sistema de Controle de Estoque — Tauste Roupas

Trabalho apresentado à Universidade Nove de Julho (UNINOVE), como parte das atividades da disciplina de Segurança da Informação do Projeto em Gestão de Sistemas Computacionais, no curso de Ciência da Computação.

SÃO PAULO

2026

RESUMO

Este trabalho apresenta um estudo de Segurança da Informação aplicado ao sistema de controle de estoque da Tauste Roupas, empresa fictícia utilizada no Projeto em Gestão de Sistemas Computacionais da UNINOVE.

O objetivo é identificar possíveis ameaças ao sistema, organizar prioridades e definir medidas de proteção para os dados e os acessos de funcionários e gerentes. Para essa análise, foi utilizada a Matriz GUT, considerando gravidade, urgência e tendência de 20 riscos levantados para o cenário proposto.

Na sequência, foram definidas 20 políticas de identidade e acesso, envolvendo autenticação, controle de permissões e proteção de sessões. Também foram registrados 20 dados ou processos relacionados à Lei Geral de Proteção de Dados (LGPD), com indicação de finalidade, hipótese legal preliminar e direitos dos titulares.

O risco de maior pontuação na Matriz GUT foi a possibilidade de SQL Injection, com 100 pontos. As recomendações apresentadas foram elaboradas a partir do estudo de materiais técnicos e representam medidas propostas para uma futura implantação. Elas não significam que todos os mecanismos já estejam implementados no protótipo.

Palavras-chave: Segurança da Informação. Matriz GUT. Controle de Acesso. LGPD. Gestão de Estoque.

SUMÁRIO

1. OBJETIVO DO ESTUDO 5
2. SISTEMA ANALISADO 5
3. MAPEAMENTO DE AMEAÇAS E MATRIZ GUT 5
3.1 Matriz GUT e prioridades 6
3.2 Análise dos riscos e medidas de mitigação 6
3.3 Exemplos de vulnerabilidades publicadas (CVE) 10
4. POLÍTICAS DE ACESSO E IDENTIDADE (IAM) 11
5. ADEQUAÇÃO À LGPD 13
5.1 Cuidados para tratamento e conservação 16
6. ANÁLISE CRÍTICA 17
7. REFERÊNCIAS 17

1. OBJETIVO DO ESTUDO

O objetivo deste estudo é analisar os principais riscos de Segurança da Informação que poderiam afetar o sistema de controle de estoque da Tauste Roupas e propor formas de diminuir esses riscos. A análise considera a importância de proteger as informações dos produtos, as movimentações do estoque e os dados pessoais dos usuários.

Para organizar o trabalho, utilizei quatro etapas: levantamento das ameaças com Matriz GUT, definição de políticas de acesso (IAM), análise de tratamentos de dados conforme a LGPD e uma avaliação crítica do risco considerado mais importante. O estudo tem caráter acadêmico e utiliza um cenário fictício.

2. SISTEMA ANALISADO

O sistema proposto para a Tauste Roupas é uma aplicação de controle de estoque voltada a uma loja de roupas. Ele permite consultar mercadorias, organizar produtos por tipo, tamanho e cor, registrar entradas e saídas e acompanhar alertas de estoque baixo ou esgotado.

Foram considerados dois perfis de uso: funcionário e gerente. O funcionário deve consultar produtos e registrar movimentações; o gerente poderá, além disso, cadastrar mercadorias e administrar parâmetros e relatórios. Essa divisão orientou o levantamento das ameaças e as propostas de controle de acesso.

As classificações e políticas apresentadas nas próximas seções descrevem requisitos de segurança para uma possível implantação. Não representam testes de invasão nem comprovação de que todos os mecanismos já existam no protótipo.

3. MAPEAMENTO DE AMEAÇAS E MATRIZ GUT

Para identificar os riscos de segurança, foram considerados exemplos documentados pela OWASP, pelo MITRE CWE e por registros de vulnerabilidades CVE. A Matriz GUT utiliza três critérios: gravidade (G), urgência (U) e tendência (T), cada um pontuado de 1 a 5. O resultado de cada risco é calculado por G × U × T.

3.1 Matriz GUT e prioridades

Tabela 1 — Matriz GUT dos riscos de Segurança da Informação

Prioridade	ID	Ameaça	G	U	T	GUT
1	03	SQL Injection	5	5	4	100
2	01	Falha no controle de acesso	5	4	4	80
3	04	Transmissão de dados sem HTTPS	5	4	4	80
4	09	Componentes desatualizados	5	4	4	80
5	17	Armazenamento inseguro de senhas	5	4	4	80
6	02	Credenciais padrão não alteradas	4	4	4	64
7	05	Cross-Site Scripting (XSS)	4	4	4	64
8	07	Força bruta no login	4	4	4	64
9	10	Validação inadequada de quantidades	4	4	4	64
10	12	Condição de corrida (Race Condition)	4	4	4	64
11	16	Consumo excessivo de recursos (DoS)	4	4	4	64
12	19	Mass Assignment	4	4	4	64
13	11	Upload de arquivos maliciosos	5	4	3	60
14	15	Exposição de backups	5	4	3	60
15	18	Path Traversal	5	4	3	60
16	20	Recuperação de senha insegura	5	4	3	60
17	06	Cross-Site Request Forgery (CSRF)	4	4	3	48
18	08	Ausência de logs e monitoramento	4	4	3	48
19	13	Sessão não invalidada após logout	4	4	3	48
20	14	Informações sensíveis em erros	4	4	3	48

Fonte: Elaboração própria (2026), a partir de ameaças documentadas pela OWASP e pelo MITRE CWE.

A maior prioridade identificada foi a SQL Injection (ID 03), com G = 5, U = 5 e T = 4, totalizando 100 pontos.

3.2 Análise dos riscos e medidas de mitigação

A seguir, são apresentados os 20 riscos considerados no levantamento. Cada item reúne uma situação possível no sistema, a justificativa da pontuação e uma medida sugerida para reduzir a exposição.

01. Falha no controle de acesso | GUT 80 (5 × 4 × 4)

Aplicação ao sistema: Um funcionário tenta executar uma operação reservada ao gerente, como cadastrar um produto ou alterar o estoque mínimo, por meio de uma requisição direta.

Justificativa GUT: A gravidade é máxima pela possibilidade de alterações administrativas; a urgência e a tendência são altas devido à ampliação de funções e acessos.

Mitigação proposta: Aplicar RBAC no servidor, negar acessos por padrão e verificar autorização em cada operação.

02. Credenciais padrão não alteradas | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Uma conta de teste ou serviço configurado com senha padrão permite que um terceiro entre no sistema sem autorização.

Justificativa GUT: Pode comprometer contas e registros; a troca das credenciais é necessária antes da implantação, pois a exposição persiste enquanto forem mantidas.

Mitigação proposta: Remover credenciais padrão, desativar contas desnecessárias e exigir contas individuais.

03. SQL Injection | GUT 100 (5 × 5 × 4)

Aplicação ao sistema: A busca de produtos ou o login concatena texto fornecido pelo usuário em uma consulta SQL, permitindo tentar alterar a consulta e alcançar registros do estoque.

Justificativa GUT: Pode comprometer integridade e confidencialidade do banco (G=5); requer prevenção imediata (U=5), com impacto crescente conforme o banco aumenta (T=4).

Mitigação proposta: Usar consultas parametrizadas, validação de entradas e permissões mínimas no banco de dados.

04. Transmissão de dados sem HTTPS | GUT 80 (5 × 4 × 4)

Aplicação ao sistema: Credenciais ou identificadores de sessão são transmitidos sem criptografia e podem ser interceptados por terceiros com acesso à comunicação.

Justificativa GUT: O vazamento de credenciais pode comprometer contas; a proteção é necessária antes do uso, e o risco aumenta com novas transmissões.

Mitigação proposta: Exigir HTTPS/TLS, certificado válido, HSTS e cookies com atributos de segurança.

05. Cross-Site Scripting (XSS) | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Um conteúdo malicioso cadastrado na descrição de produto é interpretado como código quando o gerente abre a página do item.

Justificativa GUT: Pode comprometer sessões e afetar usuários sucessivos; deve ser evitado antes da implantação.

Mitigação proposta: Codificação de saída apropriada ao contexto, validação de dados e CSP complementar.

06. Cross-Site Request Forgery (CSRF) | GUT 48 (4 × 4 × 3)

Aplicação ao sistema: Um gerente autenticado é induzido a enviar uma solicitação que altera o estoque mínimo sem perceber.

Justificativa GUT: Poderia causar mudanças indevidas; a exploração depende de condições adicionais, justificando tendência moderada.

Mitigação proposta: Validar tokens CSRF, origem da requisição, cookies SameSite e impedir alterações por GET.

07. Força bruta no login | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Tentativas automatizadas de senha buscam descobrir as credenciais de funcionários ou do gerente.

Justificativa GUT: O acesso indevido comprometeria operações de estoque; tentativas podem ocorrer rapidamente e de forma contínua.

Mitigação proposta: Rate limiting, atrasos progressivos, monitoramento e MFA obrigatório para gerente.

08. Ausência de logs e monitoramento | GUT 48 (4 × 4 × 3)

Aplicação ao sistema: Um registro de estoque é alterado sem que o sistema guarde usuário, horário e valor anterior para auditoria.

Justificativa GUT: Dificulta investigar fraudes e erros; o problema cresce conforme as operações aumentam.

Mitigação proposta: Logs protegidos de acesso e movimentações; alertas sem registrar senhas ou segredos.

09. Componentes desatualizados | GUT 80 (5 × 4 × 4)

Aplicação ao sistema: Uma biblioteca antiga usada pelo sistema apresenta uma vulnerabilidade conhecida capaz de afetar a aplicação.

Justificativa GUT: Algumas falhas podem comprometer o servidor por completo; a ausência de atualizações mantém e amplia a exposição.

Mitigação proposta: Inventário de bibliotecas, verificação de CVEs, atualizações e testes de compatibilidade.

10. Validação inadequada de quantidades | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Uma saída de 40 peças é enviada quando existem apenas 7 unidades da variação, ou são informadas entradas negativas.

Justificativa GUT: Invalida o principal objetivo do sistema; movimentações incorretas acumulam divergências.

Mitigação proposta: Validar números inteiros positivos no servidor, checar saldo e usar restrições/transações.

11. Upload de arquivos maliciosos | GUT 60 (5 × 4 × 3)

Aplicação ao sistema: Caso a função de fotografias seja implementada, alguém pode enviar um arquivo perigoso no lugar de uma imagem.

Justificativa GUT: Pode causar comprometimento grave se houver execução no servidor; depende da existência da funcionalidade.

Mitigação proposta: Permitir JPG/PNG com verificação de conteúdo, restringir tamanho e impedir execução em área pública.

12. Condição de corrida (Race Condition) | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Dois funcionários consultam as mesmas 5 peças e tentam retirar 4 cada simultaneamente, aprovando mais saídas do que o saldo permite.

Justificativa GUT: Pode gerar inconsistências recorrentes, especialmente com aumento das operações paralelas.

Mitigação proposta: Utilizar atualização atômica, transações adequadas e testes de concorrência.

13. Sessão não invalidada após logout | GUT 48 (4 × 4 × 3)

Aplicação ao sistema: Após o gerente clicar em Sair, o servidor continua aceitando um identificador de sessão antigo.

Justificativa GUT: Permite possível reutilização de sessão comprometida; depende de condições adicionais para exploração.

Mitigação proposta: Invalidar sessão no servidor e testar rejeição de tokens após logout.

14. Informações sensíveis em erros | GUT 48 (4 × 4 × 3)

Aplicação ao sistema: Uma falha na consulta de produto revela nomes de tabelas, caminhos de arquivos e outros detalhes internos.

Justificativa GUT: Pode ajudar na preparação de ataques posteriores; novas funções trazem mais oportunidades de vazamento.

Mitigação proposta: Exibir mensagens genéricas, tratar exceções e manter logs técnicos restritos.

15. Exposição de backups | GUT 60 (5 × 4 × 3)

Aplicação ao sistema: Uma cópia do banco de dados fica disponível em diretório acessível sem autenticação.

Justificativa GUT: O vazamento de uma cópia pode expor muitos registros; a exposição cresce conforme novas cópias são mantidas.

Mitigação proposta: Guardar backups em local privado, criptografar, limitar acessos e testar restauração.

16. Consumo excessivo de recursos (DoS) | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Muitas solicitações de relatórios ou consultas consomem CPU, memória e conexões, deixando o sistema indisponível.

Justificativa GUT: A indisponibilidade impede a operação da loja; picos automatizados podem piorar rapidamente.

Mitigação proposta: Rate limiting, paginação, timeout e monitoramento de recursos.

17. Armazenamento inseguro de senhas | GUT 80 (5 × 4 × 4)

Aplicação ao sistema: Um vazamento de banco expõe senhas em texto simples de funcionários e gerentes.

Justificativa GUT: Pode comprometer todas as contas; o impacto cresce com novos usuários cadastrados.

Mitigação proposta: Armazenar hashes Argon2id com salt individual e não registrar senhas em logs.

18. Path Traversal | GUT 60 (5 × 4 × 3)

Aplicação ao sistema: Na função proposta de download de relatórios, um caminho manipulado tenta alcançar arquivos fora do diretório permitido.

Justificativa GUT: Pode expor arquivos internos; depende da implementação do download e das permissões do servidor.

Mitigação proposta: Permitir somente arquivos por identificador, validar diretórios e limitar permissões.

19. Mass Assignment | GUT 64 (4 × 4 × 4)

Aplicação ao sistema: Um funcionário inclui em solicitação legítima de movimentação um campo oculto para alterar estoque mínimo, reservado ao gerente.

Justificativa GUT: Permite mudanças administrativas indevidas; amplia-se com a inclusão de novos campos.

Mitigação proposta: Usar lista explícita de campos permitidos, DTOs e autorização por propriedade.

20. Recuperação de senha insegura | GUT 60 (5 × 4 × 3)

Aplicação ao sistema: Links previsíveis, reutilizáveis ou sem validade permitem tentar redefinir a senha do gerente indevidamente.

Justificativa GUT: A tomada da conta gerencial pode comprometer funções críticas; depende do fluxo de recuperação.

Mitigação proposta: Tokens aleatórios de uso único, prazo curto, canal verificado e invalidação após uso.

3.3 Exemplos de vulnerabilidades publicadas (CVE)

Além das classificações CWE e das recomendações da OWASP, foram considerados exemplos reais de vulnerabilidades: a CVE-2021-44228 (Log4Shell), associada ao risco de componentes vulneráveis, e a CVE-2023-5227, relacionada a falhas de upload no phpMyFAQ.

4. POLÍTICAS DE ACESSO E IDENTIDADE (IAM)

Foram definidas 20 políticas de autenticação e autorização para os perfis funcionário e gerente. As propostas tratam de contas individuais, separação de responsabilidades, proteção das sessões e verificação das permissões no servidor. As medidas são requisitos para implementação futura e não funcionalidades que já tenham sido comprovadas por testes.

01. Login individual e intransferível (Autenticação)

Regra proposta: Cada funcionário e gerente terá conta e identificador exclusivos; contas compartilhadas serão proibidas.

Justificativa técnica: Permite associar movimentações e acessos à pessoa responsável.

02. Controle de acesso por perfil (RBAC) (Autorização)

Regra proposta: Funcionários consultam produtos e registram entradas/saídas; gerentes também cadastram produtos, alteram mínimos e consultam relatórios.

Justificativa técnica: Aplica menor privilégio e impede alterações administrativas indevidas.

03. Armazenamento seguro com Argon2id (Autenticação)

Regra proposta: Senhas serão armazenadas apenas como hashes Argon2id com salt individual.

Justificativa técnica: Reduz a exposição das senhas caso o banco seja comprometido.

04. Autenticação multifator (MFA) (Autenticação)

Regra proposta: Obrigatória para gerente e disponível/recomendada para funcionário; segundo fator por aplicativo autenticador.

Justificativa técnica: Dificulta invasões com senhas comprometidas e protege funções administrativas.

05. Limitação das tentativas de login (Autenticação)

Regra proposta: Aplicar limitação de frequência e atrasos progressivos após erros de login.

Justificativa técnica: Reduz ataques automatizados de adivinhação de senha.

06. Encerramento por inatividade (Autenticação)

Regra proposta: Encerrar sessões após 15 minutos sem atividade e exigir novo login.

Justificativa técnica: Evita acesso em computadores deixados sem supervisão.

07. Logout seguro (Autenticação)

Regra proposta: Invalidar a sessão no servidor imediatamente ao selecionar Sair.

Justificativa técnica: Impede a reutilização de uma sessão supostamente encerrada.

08. Recuperação segura de senhas (Autenticação)

Regra proposta: Enviar link ao e-mail verificado, com token imprevisível, de uso único e validade de 15 minutos.

Justificativa técnica: Reduz redefinições indevidas de contas.

09. Cookies protegidos (Autenticação)

Regra proposta: Usar cookies de sessão com Secure, HttpOnly e SameSite=Strict.

Justificativa técnica: Reduz exposição e utilização indevida de sessões.

10. Reautenticação em ações críticas (Autenticação)

Regra proposta: Exigir nova confirmação de identidade do gerente antes de mudanças sensíveis.

Justificativa técnica: Diminui risco de abuso de sessão aberta.

11. Revisão periódica de permissões (Autorização)

Regra proposta: Gerente revisará acessos trimestralmente; contas de desligados serão desativadas de imediato.

Justificativa técnica: Evita permissões antigas e acessos sem vínculo com a loja.

12. Cadastro controlado de usuários (Autorização)

Regra proposta: Gerente cria contas de funcionários; contas de gerente exigem aprovação administrativa específica.

Justificativa técnica: Impede criação de contas não autorizadas.

13. Autorização no servidor (Autorização)

Regra proposta: Verificar permissões para toda solicitação, mesmo quando o botão não aparece na interface.

Justificativa técnica: Evita contornar restrições pela manipulação direta das requisições.

14. Registro e monitoramento dos acessos (Autenticação)

Regra proposta: Registrar tentativas de login e acessos negados, com usuário, data, horário e resultado, sem senhas.

Justificativa técnica: Permite detectar tentativas de invasão e apurar incidentes.

15. Renovação de identificador de sessão (Autenticação)

Regra proposta: Gerar novo identificador após o login e invalidar o identificador anterior.

Justificativa técnica: Mitiga a fixação de sessão.

16. Mensagens genéricas de autenticação (Autenticação)

Regra proposta: Exibir mensagem equivalente para usuário inexistente ou senha incorreta.

Justificativa técnica: Dificulta a enumeração de contas existentes.

17. Bloqueio de senhas fracas ou vazadas (Autenticação)

Regra proposta: Rejeitar senhas comuns e identificadas em listas de credenciais comprometidas.

Justificativa técnica: Reduz a probabilidade de adivinhação de senhas.

18. Proteção contra CSRF (Autorização)

Regra proposta: Validar tokens CSRF para solicitações de alteração de estoque.

Justificativa técnica: Evita operações involuntárias originadas de sites externos.

19. Limitação de sessões simultâneas (Autenticação)

Regra proposta: Permitir uma sessão ativa por conta; novo login encerra a anterior.

Justificativa técnica: Melhora o controle das contas e reduz compartilhamento de acesso.

20. Separação de funções e aprovações (Autorização)

Regra proposta: Funcionário solicita ajustes manuais; somente gerente aprova. Entradas e saídas normais permanecem autorizadas.

Justificativa técnica: Reduz fraudes e ajustes de estoque sem supervisão.

5. ADEQUAÇÃO À LGPD

No estudo de adequação à Lei Geral de Proteção de Dados (LGPD), foram identificados 20 tipos de dados pessoais ou operações de tratamento que poderiam estar associados ao uso do sistema. Para cada registro, foram indicados a finalidade, uma hipótese legal preliminar e os direitos do titular.

Como canal de atendimento, foi proposto que as solicitações dos titulares fossem encaminhadas ao responsável pela proteção de dados da empresa, mediante conferência da identidade.

01. Nome completo do funcionário

Finalidade: Identificar o usuário responsável pelas movimentações de estoque.

Base legal proposta: Art. 7º, V - execução de contrato, se necessária.

Direitos do titular: Acesso, correção e pedido de exclusão, observada eventual obrigação de guarda.

02. E-mail individual

Finalidade: Identificação da conta, recuperação de senha e avisos de segurança.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, correção e pedido de exclusão, conforme necessidade de conservação.

03. ID único do usuário

Finalidade: Vincular operações de estoque a uma conta identificável.

Base legal proposta: Art. 7º, V - execução de contrato, se necessária.

Direitos do titular: Acesso, correção de vínculos incorretos e exclusão quando cabível.

04. Cargo/perfil de acesso

Finalidade: Estabelecer permissões de funcionário ou gerente.

Base legal proposta: Art. 7º, V - execução de contrato, se necessária.

Direitos do titular: Acesso, correção do perfil e exclusão quando cabível.

05. Endereço IP

Finalidade: Detectar acessos suspeitos e apoiar investigações.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, correção quando possível e exclusão quando cabível.

06. Data e horário do acesso

Finalidade: Auditar logins e identificar atividades anômalas.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, correção de informações incorretas e exclusão quando cabível.

07. Histórico de movimentações

Finalidade: Rastrear entradas e saídas associadas a uma pessoa.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, retificação de erro e exclusão quando cabível, preservando trilhas necessárias.

08. Identificador temporário de sessão

Finalidade: Manter a autenticação e controlar sessões ativas.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Informações sobre tratamento; encerramento por logout; exclusão quando cabível.

09. Solicitações de recuperação de senha

Finalidade: Identificar tentativas de redefinição e prevenir fraudes.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, retificação e exclusão quando cabível.

10. Hash de senha

Finalidade: Verificar credenciais sem guardar a senha em texto legível.

Base legal proposta: Art. 7º, V - execução de contrato, se necessária.

Direitos do titular: Redefinição da senha e exclusão das credenciais quando cabível.

11. Dados do dispositivo

Finalidade: Registrar navegador e sistema operacional para identificar acessos atípicos.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, correção e pedido de exclusão quando cabível.

12. Histórico de mudanças de permissões

Finalidade: Auditar quem alterou permissões de funcionário e gerente.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, retificação e exclusão quando cabível.

13. Chave de autenticação MFA

Finalidade: Validar o segundo fator do gerente.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Informações sobre tratamento, substituição da chave e exclusão quando cabível.

14. Solicitações de ajuste de estoque

Finalidade: Identificar solicitante e aprovador de correções manuais.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, retificação e exclusão quando cabível.

15. Desativação de contas

Finalidade: Registrar usuário e data de desativação após desligamento.

Base legal proposta: Art. 7º, IX - legítimo interesse, condicionado a avaliação.

Direitos do titular: Acesso, correção e exclusão quando cabível.

16. Backup dos dados pessoais

Finalidade: Recuperar contas e registros em caso de falha.

Base legal proposta: Art. 7º, V ou IX, seguindo a finalidade original; Art. 46 (segurança).

Direitos do titular: Acesso, correção e exclusão quando cabível, inclusive no ciclo de backups.

17. Pedidos de direitos do titular

Finalidade: Registrar pedidos e comprovar atendimento de direitos.

Base legal proposta: Art. 7º, II - cumprimento de obrigação legal; Art. 18.

Direitos do titular: Consultar pedidos, corrigir dados e pedir exclusão quando cabível.

18. Registros de incidentes de segurança

Finalidade: Investigar eventos e atender notificações necessárias.

Base legal proposta: Art. 7º, II, combinado com Art. 48.

Direitos do titular: Pedir informações pertinentes e correção, observadas restrições legais.

19. Armazenamento em nuvem

Finalidade: Hospedar cadastros e registros para funcionamento do sistema.

Base legal proposta: Art. 7º, V ou IX, conforme finalidade original; Art. 39.

Direitos do titular: Acesso, correção e exclusão quando cabível, inclusive perante prestadores.

20. Exclusão/anonimização de dados

Finalidade: Encerrar o tratamento de informações que deixaram de ser necessárias.

Base legal proposta: Art. 7º, V ou IX da finalidade original; Arts. 15 e 16.

Direitos do titular: Solicitar eliminação quando cabível, respeitadas obrigações de conservação.

5.1 Cuidados para tratamento e conservação

Os registros pessoais devem ser necessários para a finalidade informada, acessíveis somente a perfis autorizados e mantidos pelo período adequado. Backups, registros de

acesso e prestadores de serviços em nuvem precisam seguir as mesmas medidas de proteção e atendimento aos titulares.

O artigo 46 da LGPD aborda medidas técnicas e administrativas de segurança; os artigos 15, 16 e 18 tratam de aspectos relacionados ao término do tratamento, à conservação dos dados e aos direitos dos titulares. A avaliação definitiva dependeria da operação real do sistema e de orientação jurídica adequada.

6. ANÁLISE CRÍTICA

Na Matriz GUT da Tauste Roupas, identifiquei a SQL Injection como principal ameaça, com 100 pontos (G=5, U=5, T=4). Em um cenário de falha, um invasor poderia explorar o campo de pesquisa de produtos ou outro formulário que montasse consultas SQL por concatenação de texto. Isso permitiria tentar modificar o comportamento da consulta e comprometer informações como cadastros de produtos, quantidades, preços e movimentações. A exploração poderia afetar diretamente a integridade dos relatórios e o objetivo central do projeto, que é manter um controle confiável do estoque por tamanho e cor.

Para reduzir esse risco, pesquisei e defini como requisito a utilização de consultas parametrizadas, que mantêm separados os valores informados pelo usuário e a estrutura do comando SQL. Também estabeleci a aplicação do menor privilégio à conta usada para acessar o banco e a validação de dados recebidos do formulário. Essas proteções foram planejadas com base nas recomendações da OWASP e deverão ser implementadas e verificadas por testes antes da disponibilização do sistema.

7. REFERÊNCIAS

OWASP. OWASP Top 10: 2025.
https://top10.owasp.org/2025/

OWASP. API Security Top 10: 2023.
https://owasp.org/API-Security/editions/2023/en/0x11-t10/

OWASP. Cheat Sheet Series.
https://cheatsheetseries.owasp.org/

MITRE. Common Weakness Enumeration (CWE).
https://cwe.mitre.org/

NIST. National Vulnerability Database (NVD).
https://nvd.nist.gov/

NIST. Security and Privacy Controls — SP 800-53.
https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

NIST. Digital Identity Guidelines — SP 800-63B.

https://pages.nist.gov/800-63-4/sp800-63b.html

BRASIL. Lei nº 13.709/2018 — Lei Geral de Proteção de Dados Pessoais.
https://www2.camara.leg.br/legin/fed/lei/2018/lei-13709-14-agosto-2018-787077-normaatualizada-pl.html

ANPD. Portal oficial da Autoridade Nacional de Proteção de Dados.
https://www.gov.br/anpd/pt-br